

## Guía Metodológica Detallada

### Encuesta sobre Pirámide del Dolor, Indicadores y Métricas de Detección

#### 1. Objetivo general

Esta guía explica cómo utilizar la encuesta para evaluar el grado de adopción práctica de la Pirámide del Dolor y, en general, de la detección basada en distintos niveles de indicadores (IoC, artefactos, TTP) en organizaciones de diversos sectores y tamaños. El propósito no es sancionar, sino diagnosticar con la mayor honestidad posible dónde se sitúa cada entidad en el espectro que va de “coleccionista de hashes” a “ingeniero del dolor adversario”.

#### 2. Población objetivo y unidad de análisis

La encuesta está dirigida a organizaciones con algún tipo de responsabilidad formal en materia de ciberseguridad, independientemente de que dispongan o no de SOC propio.

La unidad de análisis principal es la organización como tal; no obstante, en grandes grupos empresariales puede ser pertinente aplicar la encuesta por unidad de negocio o por región, siempre que mantengan cierta autonomía en su gestión de seguridad.

Es recomendable que la respuesta sea coordinada por la función de CISO o equivalente. Si varias personas contribuyen (p. ej., responsable de SOC, de TI y de riesgo), conviene consolidar una única respuesta consensuada por organización.

#### 3. Estructura de la encuesta

La encuesta se divide en nueve bloques:

1. Información general de la organización.
2. Marco conceptual y uso de la Pirámide del Dolor.
3. Indicadores de bajo nivel (hashes, IP, dominios).
4. Artefactos de red y host.
5. Herramientas del adversario y TTP (MITRE ATT&CK).
6. Métricas de tiempo, eficacia y “dolor infligido”.
7. Gobernanza, coordinación y ámbito nacional.
8. Normativa, cumplimiento y marcos externos.
9. Visión, retos y próximos pasos.

Cada bloque persigue medir un aspecto distinto de la madurez: no sólo la presencia de tecnología, sino la calidad de su uso y, sobre todo, el estado de las métricas y la gobernanza.

#### 4. Tipos de preguntas y escalas de respuesta

La mayor parte de las preguntas son cerradas con opciones predefinidas, diseñadas para facilitar la comparación entre organizaciones. Se utilizan principalmente:

- Escalas de frecuencia (p. ej., “al menos mensualmente”, “puntualmente”, “nunca”).
- Escalas de intensidad o relevancia (p. ej., “crítico”, “importante”, “marginal”).
- Escalas de madurez implícita (p. ej., “formalizado y revisado”, “prácticas informales”, “no existe”).
- Preguntas dicotómicas (sí/no) con matices intermedios (“no lo sé”).
- Preguntas abiertas para recoger matices cualitativos.

Es importante mantener las opciones tal como están formuladas, porque cada una se ha pensado como “punto de anclaje” dentro de un continuo de madurez. La redacción, con cierto tono irónico en algunos casos, está deliberadamente orientada a invitar a la reflexión más que a favorecer respuestas complacientes.

## 5. Aplicación de la encuesta

### 5.1 Modalidad

La encuesta puede aplicarse:

- En formato electrónico (formulario web, herramienta de encuestas).
- En entrevistas estructuradas (por ejemplo, como parte de una evaluación de madurez).
- Como autoevaluación interna (p. ej., previo a un proyecto de mejora).

En cualquier modalidad, se recomienda acompañarla de una breve explicación de objetivos, enfatizando que no se busca una auditoría al uso, sino material para entender mejor dónde hace falta invertir inteligencia, tiempo y presupuesto.

### 5.2 Duración

El tiempo estimado para responder de forma reflexiva oscila entre 30 y 45 minutos, dependiendo del grado de complejidad de la organización. Es preferible que la persona responda en una sola sesión, para minimizar incoherencias.

### 5.3 Acompañamiento

Si se utiliza en el contexto de una evaluación externa (p. ej., a operadores críticos), es recomendable que el equipo evaluador:

- Revise previamente documentación relevante (políticas, organigramas, reportes).
- Realice una breve reunión inicial para aclarar conceptos clave (Pirámide, TTP, ATT&CK).
- Esté disponible para aclarar términos durante el llenado.

## 6. Interpretación de resultados

### 6.1 Enfoque general

Los resultados no deben interpretarse como una nota única (aprobado/suspenso), sino como un perfil de madurez a lo largo de los distintos niveles de la Pirámide. Una organización puede estar muy avanzada en gobernanza, pero aún centrada en IoC triviales; otra puede tener detección muy robusta, pero métricas y reportes rudimentarios.

Se recomienda analizar siempre:

- Distribución de prácticas por bloque.
- Coherencia interna (por ejemplo, organizaciones que afirman usar ATT&CK extensivamente, pero no miden cobertura).
- Posibles puntos de fricción (p. ej., alta dependencia de feeds externos sin métricas de eficacia).

### 6.2 Agrupación por niveles de la Pirámide

Para análisis cuantitativo, puede asignarse a cada pregunta una “carga” sobre uno o varios niveles de la Pirámide (ver documento de mapeo normativo) y calcular índices parciales, como:

- Índice de madurez en IoC de bajo nivel.
- Índice de madurez en artefactos de red/host.
- Índice de madurez en TTP y comportamiento.
- Índice de gobernanza y métricas.

Estos índices se pueden normalizar de 0 a 100, para facilitar su uso en cuadros de mando.

### 6.3 Uso comparativo

Aplicada a múltiples organizaciones, la encuesta permite:

- Comparar sectores (p. ej., salud vs energía).
- Analizar evolución temporal (p. ej., repetir cada 2 años).
- Identificar “islas de excelencia” y áreas comunes de debilidad.

La recomendación metodológica es evitar la tentación de utilizar los resultados como ranking público. Son más valiosos como espejo interno y como base para programas de mejora sectoriales.

## 7. Calidad de los datos

### 7.1 Honestidad y “sesgo de maquillaje”

El principal riesgo de este tipo de encuesta es el maquillaje: responder “lo que debería ser” en lugar de “lo que es”. Para mitigarlo:

- Dejar claro que el valor de la encuesta reside en la sinceridad.
- Garantizar confidencialidad de resultados individuales cuando proceda.
- Enmarcar el ejercicio como parte de un proceso de mejora, no de auditoría punitiva.

### 7.2 Coherencia interna

Conviene revisar las respuestas en busca de inconsistencias obvias, por ejemplo:

- Afirmar “no tenemos SOC” y, simultáneamente, “tenemos métricas detalladas de MTTD por tipo de alerta”.
- Declarar “no conocemos ATT&CK” pero “medimos cobertura ATT&CK de técnicas críticas”.

En estos casos, la metodología debería permitir aclaraciones posteriores o, al menos, etiquetar las respuestas como “requieren revisión”.

## 8. Consideraciones éticas y de gobernanza

Aunque la encuesta trata sobre capacidades técnicas, el trasfondo es profundamente organizativo y, en cierto modo, político. Preguntarse por el “dolor infligido al adversario” es, indirectamente, preguntarse por la capacidad de causar fricción estructural en un ecosistema que también incluye usuarios, proveedores y ciudadanos.

Se recomienda:

- Explicar claramente cómo se utilizarán los resultados.
- Determinar quién tendrá acceso a los informes consolidados.
- Establecer un mecanismo para que las organizaciones respondentes puedan comentar o matizar la interpretación que se haga de sus datos.

## 9. Integración con otras iniciativas

Esta encuesta puede integrarse con:

- Evaluaciones de madurez NIS2 / ENS.
- Programas de ejercicios de ciber crisis.
- Proyectos de implantación de marcos como ATT&CK, D3FEND o Zero Trust.
- Planes de inversión plurianuales en ciberseguridad.

La clave está en que no compita con estas iniciativas, sino que proporcione una lente específica sobre la calidad de la detección a lo largo de la Pirámide del Dolor.

## 10. Recomendaciones finales

- No obsesionarse con obtener una “buena nota”; obsesionarse con que la nota sea veraz.
- Mantener la encuesta viva: actualizarla cada 2–3 años para reflejar cambios tecnológicos y normativos.
- Usarla como pretexto para conversaciones difíciles dentro de la organización: ¿estamos realmente poniendo el foco donde más duele al adversario?

Si después de todo esto alguien sigue pensando que lo importante es “cuántos hashes hemos bloqueado este mes”, vuelva al inicio y léase de nuevo el título de la encuesta.